NEXUS SECURITY ADVISORS

CMMC / NIST SP 800-171 Readiness Self-Check

Defense and aerospace suppliers handling Controlled Unclassified Information (CUI)

A readiness self-check against CMMC Level 2 / NIST SP 800-171 Rev. 2. It is not a formal assessment and does not cover all 110 requirements; use it to find the biggest gaps first. As of October 2026, CMMC Phase 2 (C3PAO by default) is suspended, but DFARS 252.204-7012, NIST SP 800-171, SPRS scores, and annual affirmations still apply.

Organization: _____ Completed by: _____ Date: _____

☐	ID	Section	Requirement	Reference	Priority	Evidence
☐	CMMC-01	Scope & Program	Identify where CUI is received, stored, processed, and transmitted, and document data flows and the assessment boundary	CMMC scoping guidance	High	CUI data-flow diagram; asset inventory with CUI/security-protection/out-of-scope tags
☐	CMMC-02	Scope & Program	Write and maintain a System Security Plan (SSP) describing how each requirement is met	NIST 800-171 3.12.4	High	Current, approved SSP
☐	CMMC-03	Scope & Program	Track open gaps in a Plan of Action & Milestones (POA&M) with owners and dates	NIST 800-171 3.12.2	High	POA&M with owners, due dates, status
☐	CMMC-04	Scope & Program	Calculate your NIST SP 800-171 score and post it to SPRS; complete the annual senior-official affirmation	DFARS 252.204-7019/7020; CMMC affirmation	High	SPRS confirmation; signed affirmation
☐	CMMC-05	Scope & Program	Confirm cloud services handling CUI meet FedRAMP Moderate (or equivalent) and flow down DFARS 7012	DFARS 252.204-7012 (b)(2)(ii)(D)	High	Provider FedRAMP package or equivalency letter; subcontract clauses
☐	CMMC-06	Access Control	Limit system access to authorized users, processes, and devices	NIST 800-171 3.1.1	High	Access control policy; user access reviews
☐	CMMC-07	Access Control	Monitor and control remote access sessions	NIST 800-171 3.1.12	Medium	VPN/ZTNA configuration; remote access logs
☐	CMMC-08	Identification & Authentication	Use multifactor authentication for privileged accounts and for network access to non-privileged accounts	NIST 800-171 3.5.3	High	MFA configuration screenshots; exception list
☐	CMMC-09	Awareness & Training	Provide security awareness training, including insider-threat awareness	NIST 800-171 3.2.1 / 3.2.3	Medium	Training records and completion rates
☐	CMMC-10	Audit & Accountability	Create and retain system audit logs sufficient to investigate unlawful or unauthorized activity	NIST 800-171 3.3.1	High	Log sources list; retention settings; SIEM screenshots
☐	CMMC-11	Configuration Management	Establish baseline configurations and inventories of systems, and enforce security settings	NIST 800-171 3.4.1 / 3.4.2	High	Hardening baselines (e.g., CIS Benchmarks); inventory

☐	ID	Section	Requirement	Reference	Priority	Evidence
☐	CMMC-12	Incident Response	Maintain an incident-handling capability, and report cyber incidents to DoD within 72 hours	NIST 800-171 3.6.1; DFARS 252.204-7012(c)	High	IR plan; DIBNet access; tabletop results
☐	CMMC-13	Maintenance	Require MFA for nonlocal (remote) maintenance sessions	NIST 800-171 3.7.5	Medium	Remote maintenance procedure; MFA evidence
☐	CMMC-14	Media Protection	Sanitize or destroy media containing CUI before disposal or reuse	NIST 800-171 3.8.3	Medium	Sanitization records / certificates of destruction
☐	CMMC-15	Personnel Security	Protect CUI during personnel actions such as terminations and transfers	NIST 800-171 3.9.2	Medium	Off-boarding checklist; access revocation logs
☐	CMMC-16	Physical Protection	Limit physical access to systems and equipment to authorized individuals	NIST 800-171 3.10.1	Medium	Badge/visitor logs; facility access list
☐	CMMC-17	Risk Assessment	Scan for vulnerabilities periodically and when new vulnerabilities are identified	NIST 800-171 3.11.2	High	Scan reports; scan schedule
☐	CMMC-18	System & Communications Protection	Monitor and control communications at external and key internal boundaries	NIST 800-171 3.13.1	High	Firewall rules; network diagram
☐	CMMC-19	System & Communications Protection	Use FIPS-validated cryptography to protect the confidentiality of CUI	NIST 800-171 3.13.11	High	FIPS 140 certificate numbers for encryption modules
☐	CMMC-20	System & Information Integrity	Identify, report, and correct system flaws in a timely manner	NIST 800-171 3.14.1	High	Patch SLAs; patch compliance reports

Readiness self-check for general guidance only. Not legal advice and not a formal assessment or certification. Confirm requirements against official sources.